PAYNEST CAPSTONE PROJECT

Governance, Risk and Compliance (GRC)

Analyst: Maureen Uzoewulu

September 12, 2026

Table of Contents

Case Study: PayNest Technologies 3

Company Introduction 3

The Business Problem 3

Task 3

Executive Summary 4

ISMS Scope Statement 6

ISO/IEC 27001 Gap Analysis 7

Risk Register 11

Annex A Control Recommendations (Mapped to Risks) 13

PayNest Statement of Applicability (SoA) 14

PDCA improvement plan 21

Conclusion 22

References 23

Case Study: PayNest Technologies

Company Introduction

PayNest Technologies is a growing Nigerian fintech startup that provides digital payment services to individuals and small businesses. As the company grows, it handles more customer information, transaction data, employee information, financial records, application and source code, and cloud-based systems. Management has therefore decided to implement an Information Security Management System (ISMS) aligned with ISO/IEC 27001. Your task is to define the ISMS scope, identify gaps, assess risk, and recommend Annex A controls to prepare PayNest for certification.

The Business Problem

PayNest has grown quickly, but its information security processes have not grown at the same pace. An internal review identified several weaknesses across governance, risk management, and control implementation, leaving the startup exposed as it scales.

Purpose: Apply ISO/IEC 27001 principles to design a basic Information Security Management System, recommend appropriate Annex A controls, and prepare the startup for certification. Current challenges include:

- No clearly defined ISMS scope
- Security policies are incomplete
- No formal information asset inventory
- Risk assessments are inconsistent
- Security controls have not been formally selected
- No Statement of Applicability (SoA)
- Security awareness training is irregular
- Third-party security checks are inconsistent

Task

01 - ISMS Scope Statement: Clearly define what is included within PayNest's ISMS.

02 - Gap Analysis: Identify PayNest's current security gaps against ISO/IEC 27001.

03 - Risk Register: Document key risks, their likelihood, impact, and proposed treatment.

04 - Annex A Control Recommendations: Select relevant controls and explain why they address the identified risks.

05 - Statement of Applicability (SoA): Document the selected controls and their applicability/implementation status.

06 - PDCA Improvement Plan: Recommend practical actions PayNest should take to improve its ISMS.

07 - Final Capstone Report: Combine your findings into a professional GRC report.

Executive Summary

PayNest Technologies is a growing Nigerian fintech startup that provides digital payment services to individuals and small businesses. As the organization expands, it increasingly relies on cloud-based systems and processes sensitive customer information, transaction data, employee records, financial information, and application source code. However, PayNest's security practices have not kept pace with its business growth. The organization currently has no clearly defined ISMS scope, incomplete security policies, no formal information-asset inventory, inconsistent risk assessments, irregular security-awareness training, inconsistent third-party security checks, and no formal Statement of Applicability (SoA). These weaknesses expose PayNest to data breaches, fraud, cyberattacks, service disruption, regulatory non-compliance, and loss of customer trust.

This capstone report recommends establishing an Information Security Management System (ISMS) aligned with ISO/IEC 27001:2022. The proposed ISMS scope covers PayNest's digital payment platform, customer and transaction data, employee and financial records, source code, cloud environments, corporate endpoints and networks, business processes, personnel, and relevant suppliers. The scope also includes the interfaces with third-party cloud providers, payment partners, technology vendors, and contractors that support or process PayNest information.

A review of PayNest's current environment identified critical gaps: no defined ISMS scope, incomplete security policies, no asset inventory, inconsistent risk assessments, no formal control selection, no Statement of Applicability, irregular security awareness training, and weak third-party security oversight. These gaps directly conflict with ISO requirements, including Clause 4.3 (scope definition), Clause 5.2 (policy), Clause 6.1 (risk management), and Clause 7.2–7.5 (competence, awareness, documented information).

A structured risk assessment identified high-impact risks, including unauthorized access, insecure cloud configurations, malware infections, data loss, supplier compromise, insecure software development, and a lack of incident response capability. These risks were mapped to relevant Annex A controls, including access control (A.5.15–5.18), cloud security (A.5.23), malware protection

(A.8.7), backup (A.8.13), supplier security (A.5.19–5.23), secure development (A.8.25–8.31), and incident management (A.5.24–5.27).

PayNest developed a Statement of Applicability (SoA) to document selected controls, their justification, and implementation status. This forms the foundation for PayNest's control environment and certification readiness.

Finally, a PDCA-based improvement plan outlines how PayNest will establish policies, implement controls, conduct internal audits, monitor performance, and drive continual improvement. This structured approach transitions PayNest from informal security practices to a defined, risk-driven, and audit-ready ISMS.

Overall, implementing ISO/IEC 27001 positions PayNest to strengthen its security posture, meet regulatory expectations, protect customer trust, and prepare for future certification.

ISMS Scope Statement

The PayNest Technologies Information Security Management System (ISMS) applies to the people, processes, information, technology, cloud services, and physical working environments used to design, develop, operate, support, manage, and improve PayNest's digital payment services for individual customers and small businesses in Nigeria, including remote workers accessing systems globally. This includes:

- Customer onboarding and identity verification
- Payment processing, transaction management, and reconciliation
- Management of customer information, transaction data, employee data, and financial records
- Development, deployment, and maintenance of PayNest's payment application, APIs, and source code
- Cloud-hosted infrastructure supporting production, development, and testing environments
- Internal IT systems, networks, user endpoints, and communication channels
- Third-party services including cloud hosting, payment gateways, and outsourced development
- All employees, contractors, and temporary staff with access to PayNest information assets

ISO/IEC 27001 requires that "the organization shall determine the boundaries and applicability of the information security management system to establish its scope." (Clause 4.3)

ISO/IEC 27001 Gap Analysis

The following gap analysis is based on the documented PayNest scenario and maps the current state to key ISO/IEC 27001:2022 requirements and relevant Annex A controls. The case study indicates that PayNest has some existing security activity, but it is informal, incomplete, inconsistently applied, and largely reactive.

Table 1: Gap Analysis

ISO Requirement	Current State at PayNest	Gap Identified	Impact
Clauses 4.1–4.4: Organizational Context & Scope	No clearly defined ISMS scope	No approved scope, context assessment, interested-party register, or process/interface mapping	Unclear accountability; important systems or suppliers may be omitted from security management
Clauses 5.1–5.3: Leadership and governance	Management has approved an ISMS project, but governance arrangements are not defined	No formal security roles, authorities, reporting lines, or assigned ISMS accountability	Decisions may be delayed; security responsibilities may be ignored or duplicated
Clause 5.2; A.5.1: Information security policy	Security policies are incomplete	No approved overarching policy and insufficient topic-specific policies	Inconsistent practices; employees lack clear mandatory rules
Clause 6.1.2; A.5.9–A.5.13: Asset management	No formal information asset inventory	No asset register, asset owners, classification scheme, labelling, or handling rules	Sensitive data and critical systems may be unknown, unprotected, or improperly retained

Clauses 6.1.1–6.1.2 and 8.2: Risk assessment	Risk assessments are inconsistent, and decisions are made after incidents	No documented methodology, risk criteria, risk appetite, risk owners, repeatable assessment process, or assessment schedule	Risks are not prioritized before harm occurs; resources may be allocated poorly
Clause 6.1.3 and 8.3: Risk treatment and SoA	Controls have not been formally selected; no SoA	No risk treatment plan, control selection rationale, implementation status, or residual-risk acceptance	Gaps remain unmanaged; PayNest cannot demonstrate ISO/IEC 27001 conformity
Clause 6.2: Information security objectives	No evidence of documented objectives	No measurable objectives, owners, timelines, resources, or performance measures	ISMS progress cannot be measured or managed
Clauses 7.2–7.3; A.6.3: Competence and awareness	Training is irregular	No role-based training plan, induction process, training records, phishing education, or effectiveness measurement	Increased likelihood of phishing, misuse, credential compromise, and reporting failures
Clause 7.5: Documented information	Documentation is incomplete	No consistent document control, ownership, approval, versioning, retention, or review process	Outdated or unauthorized policies/procedures may be used

A.5.15–A.5.18; A.8.2–A.8.5: Access control	No evidence of a formal access-control lifecycle	No consistent access approvals, MFA standard, privileged access governance, periodic access reviews, or timely deprovisioning	Unauthorized access, account compromise, fraud, and excessive privileges
A.8.25–A.8.33: Secure software development	Application and source code are in scope, but formal controls are not described	No established secure SDLC, secure coding standard, security testing, code-access controls, or separation of environments	Vulnerable or malicious code may reach production; customer and transaction data may be exposed
A.5.23; A.8.9; A.8.20–A.8.22: Cloud security	PayNest uses cloud-based systems, but assurance mechanisms are unspecified	No cloud security baseline, shared-responsibility mapping, configuration standards, logging requirements, or cloud exit planning	Misconfiguration, exposed storage, weak monitoring, and provider-dependency risks
A.5.19–A.5.22: Supplier security	Third-party security checks are inconsistent	No formal supplier due diligence, risk tiering, security clauses, assurance reviews, or change-monitoring process	Supplier breach or service failure can affect PayNest customers and operations
A.5.24–A.5.28: Incident management	Security decisions are largely reactive	No documented incident response plan, reporting channel, severity classification,	Slow/inconsistent response could worsen a breach and impair recovery

		investigation process, evidence handling, or lessons-learned process	
A.5.29–A.5.30; A.8.13–A.8.14: Resilience and backup	No documented backup or continuity practices are described	No backup policy, recovery testing, recovery objectives, business-impact analysis, or ICT continuity testing	Payment-service outage, data loss, prolonged customer impact, and reputational harm
A.8.15–A.8.17: Logging and monitoring	No evidence of centralized monitoring or alerting	Insufficient event logs, protection of logs, anomaly monitoring, alert triage, and time synchronization	Attacks or fraud may remain undetected; investigations may be ineffective

Risk Register

ISO/IEC 27001 requires a documented, repeatable risk assessment process that identifies confidentiality, integrity, and availability risks; identifies risk owners; assesses consequence and likelihood; and prioritizes risk treatment. It also requires a documented risk treatment process, an SoA, risk-owner approval of treatment plans, and acceptance of residual risk.

Risk Rating Scale:

		Impact		
		Low (1)	Medium (2)	High (3)
Likelihood	Low (1)	1	2	3
	Medium (2)	2	4	6
	High (3)	3	6	9

Table 2: Risk Register

Risk ID and Description	Likelihood	Impact	Score	Treatment	Owner
R1 - Unauthorized access due to weak access control	3	3	9	Enforce MFA, formal joiner-mover-leaver process, privileged-access controls, periodic access review, and secure credential handling	Head of IT/Cloud Operations
R2 - Data breach from insecure	3	3	9	Establish cloud-security standards, secure configurations, least privilege, encryption, logging,	Head of IT/Cloud Operations

cloud configuration				configuration monitoring, and cloud-provider governance	
R3 - Malware infection on employee endpoints	2	3	6	Mandate induction and annual training, targeted role-based training, phishing simulations, policy acknowledgement, and awareness metrics	HR Manager and Information Security Manager
R4 - Loss of customer data due to missing backups	2	3	6	Define backup and recovery policy, recovery objectives, immutable/offsite backups where appropriate, restore testing, redundancy, and continuity exercise	Head of IT/Cloud Operations
R5 - Third-party compromise affecting PayNest systems	3	2	6	Maintain legal and contractual obligations register; conduct privacy review; define records, retention, and PII protection requirements; monitor changes	Legal/Compliance Lead
R6 - Application vulnerabilities due to insecure coding	3	3	9	Implement SDLC, code review, SAST/DAST (Static/Dynamic Application Security Testing), security acceptance criteria, vulnerability remediation, and segregation of development/test/production environments.	Head of Engineering
R7 - Lack of incident response	2	3	6	Establish an incident response policy, reporting channel, playbooks, incident team, tabletop exercises, evidence procedures, and post-incident review	Information Security Manager

leading to prolonged outages					
R8 - Insider misuse due to lack of monitoring	2	3	6	Centralize and protect logs, implement alerting and anomaly monitoring, define use cases and escalation procedures, synchronize clocks, and retain logs	Head of IT/Cloud Operations

Annex A Control Recommendations (Mapped to Risks)

Table 3: Annex A Control Recommendations

Risk	Recommended Annex A Control	Justification
R1 Unauthorized access	A.5.15 Access Control, A.5.16 Identity Management, A.5.17 Authentication Information	Establish structured access rules and identity lifecycle
R2 Cloud misconfiguration	A.5.23 Cloud Security, A.8.9 Configuration Management	Ensures secure cloud acquisition, use, and exit
R3 Malware	A.8.7 Protection Against Malware	Reduces risk of infection and data compromise
R4 Data loss	A.8.13 Information Backup	Ensure recoverability of critical data
R5 Supplier risk	A.5.19–5.23 Supplier & ICT Supply Chain Security	Formalizes supplier security requirements
R6 Insecure development	A.8.25 Secure Development Lifecycle, A.8.28 Secure Coding	Reduces vulnerabilities in PayNest's payment application
R7 Incident response	A.5.24–5.27 Incident Management	Enables structured response and learning
R8 Insider misuse	A.8.15 Logging, A.8.16 Monitoring	Enables detection of anomalous behavior

PayNest Statement of Applicability (SoA)

The Statement of Applicability is a mandatory ISO/IEC 27001 deliverable. It must identify the controls necessary for risk treatment, justify their inclusion, state whether they are implemented, and justify exclusions of Annex A controls. The following is a baseline SoA for PayNest. Most controls are recorded as not implemented or partially implemented/needs validation, because no specific operating controls were stated.

Table 4: Statement of Applicability (SoA)

Control	Applicable?	Justification	Current Status
A.5. Policies for information security	Yes	PayNest policies are incomplete and need formal management approval	Partially implemented
A.5.2 Information security roles and responsibilities	Yes	ISMS accountability and control ownership must be established	Not implemented
A.5.3 Segregation of duties	Yes	Necessary for payment operations, production changes, and fraud reduction	Not implemented
A.5.8 Information security in project management	Yes	PayNest develops and changes payment technology	Not implemented
A.5.9 Inventory of information and other associated assets	Yes	Asset inventory is explicitly absent	Not implemented

Control	Applicable?	Justification	Current Status
A.5.10 Acceptable use of information and other associated assets	Yes	Personnel require clear use and handling expectations	Not implemented
A.5.12 Classification of information	Yes	Customer, transaction, employee, and financial data have different protection needs	Not implemented
A.5.13 Labelling of information	Yes	Supports consistent handling of classified information	Not implemented
A.5.14 Information transfer	Yes	Information is transmitted across internal systems and third parties	Not implemented
A.5.15 Access control	Yes	Access-control rules are fundamental to PayNest systems and sensitive data	Not implemented
A.5.16 Identity management	Yes	User identities must be managed through their lifecycle	Not implemented
A.5.17 Authentication information	Yes	Credentials and secrets require formal protection	Partially implemented/needs validation
A.5.18 Access rights	Yes	Provisioning, review, modification, and removal require formal control	Not implemented
A.5.19 Supplier relationships	Yes	Supplier checks are currently inconsistent	Not implemented

Control	Applicable?	Justification	Current Status
A.5.20 Security within supplier agreements	Yes	Third parties require written security and privacy obligations	Not implemented
A.5.22 Monitoring and change management of supplier services	Yes	Continuing supplier assurance is required	Not implemented
A.5.23 Information security for use of cloud services	Yes	Cloud-based systems are in scope and support core services	Not implemented
A.5.24 Incident management planning and preparation	Yes	Incident response is currently reactive	Not implemented
A.5.25 Assessment and decision on information security events	Yes	PayNest needs consistent event classification and escalation	Not implemented
A.5.26 Response to information security incidents	Yes	Timely, coordinated response is required	Not implemented
A.5.27 Learning from information security incidents	Yes	Enables continual improvement after events	Not implemented
A.5.28 Collection of evidence	Yes	Supports investigation, contractual, and legal needs	Not implemented

Control	Applicable?	Justification	Current Status
A.5.29 Information security during disruption	Yes	Security must be preserved during outages or emergency conditions	Not implemented
A.5.30 ICT readiness for business continuity	Yes	Payment service availability and recovery are critical	Not implemented
A.5.31 Legal, statutory, regulatory and contractual requirements	Yes	Fintech operations and PII processing create compliance obligations	Partially implemented/needs validation
A.5.33 Protection of records	Yes	Financial, transaction, customer, and corporate records require protection	Not implemented
A.5.34 Privacy and protection of PII	Yes	PayNest processes customer and employee personal information	Partially implemented/needs validation
A.5.35 Independent review of information security	Yes	Supports assurance and certification readiness	Not implemented
A.5.36 Compliance with policies, rules and standards	Yes	PayNest must test adherence to its new requirements	Not implemented
A.6.3 Information security awareness, education and training	Yes	Irregular training is an identified weakness	Partially implemented

Control	Applicable?	Justification	Current Status
A.6.6 Confidentiality or non-disclosure agreements	Yes	Employees, contractors, and suppliers may access confidential data	Partially implemented/needs validation
A.6.7 Remote working	Yes	Remote access to cloud systems and information must be protected	Not implemented
A.6.8 Information security event reporting	Yes	Personnel need a timely reporting mechanism	Not implemented
A.7.7 Clear desk and clear screen	Yes	Protects visible paper and electronic information	Not implemented
A.7.9 Security of assets off-premises	Yes	Endpoints may be used outside PayNest premises	Not implemented
A.8.1 User endpoint devices	Yes	Endpoints access sensitive data and cloud services	Partially implemented/needs validation
A.8.2 Privileged access rights	Yes	Administrative access represents high-impact risk	Not implemented
A.8.3 Information access restriction	Yes	Least privilege is necessary for sensitive systems and data	Not implemented
A.8.4 Access to source code	Yes	Source code is a critical asset supporting payment services	Partially implemented/needs validation

Control	Applicable?	Justification	Current Status
A.8.5 Secure authentication	Yes	Strong authentication reduces account takeover risk	Partially implemented/needs validation
A.8.7 Protection against malware	Yes	Helps protect endpoints from malware and ransomware	Partially implemented/needs validation
A.8.8 Management of technical vulnerabilities	Yes	No formal vulnerability management is described	Not implemented
A.8.9 Configuration management	Yes	Cloud and system configuration errors pose material risk	Not implemented
A.8.13 Information backup	Yes	Required for recovery from data loss or ransomware	Not implemented
A.8.14 Redundancy of information processing facilities	Yes	Supports availability of critical payment services	Not implemented
A.8.15 Logging	Yes	Required for detection, investigation, and assurance	Not implemented
A.8.16 Monitoring activities	Yes	Needed to detect anomalous and potentially fraudulent activity	Not implemented
A.8.20 Network security	Yes	Protects systems, applications, and data flows	Partially implemented/needs validation

Control	Applicable?	Justification	Current Status
A.8.22 Segregation of networks	Yes	Limits lateral movement and isolates production assets	Not implemented
A.8.24 Use of cryptography	Yes	Protects sensitive information in transit and at rest	Partially implemented/needs validation
A.8.25 Secure development life cycle	Yes	PayNest develops and maintains payment applications	Not implemented
A.8.26 Application security requirements	Yes	Security must be defined before systems are built or acquired	Not implemented
A.8.28 Secure coding	Yes	Reduces application vulnerabilities	Not implemented
A.8.29 Security testing in development and acceptance	Yes	Detects security defects before production deployment	Not implemented
A.8.31 Separation of development, test and production	Yes	Prevents uncontrolled production access and data misuse	Not implemented
A.8.32 Change management	Yes	Changes to systems and cloud environments require controlled approval and rollback	Not implemented

PDCA improvement plan

ISO/IEC 27001 requires PayNest not only to implement controls, but also to monitor and evaluate the ISMS, conduct internal audits, perform management reviews, correct nonconformities, and continually improve its suitability, adequacy, and effectiveness.

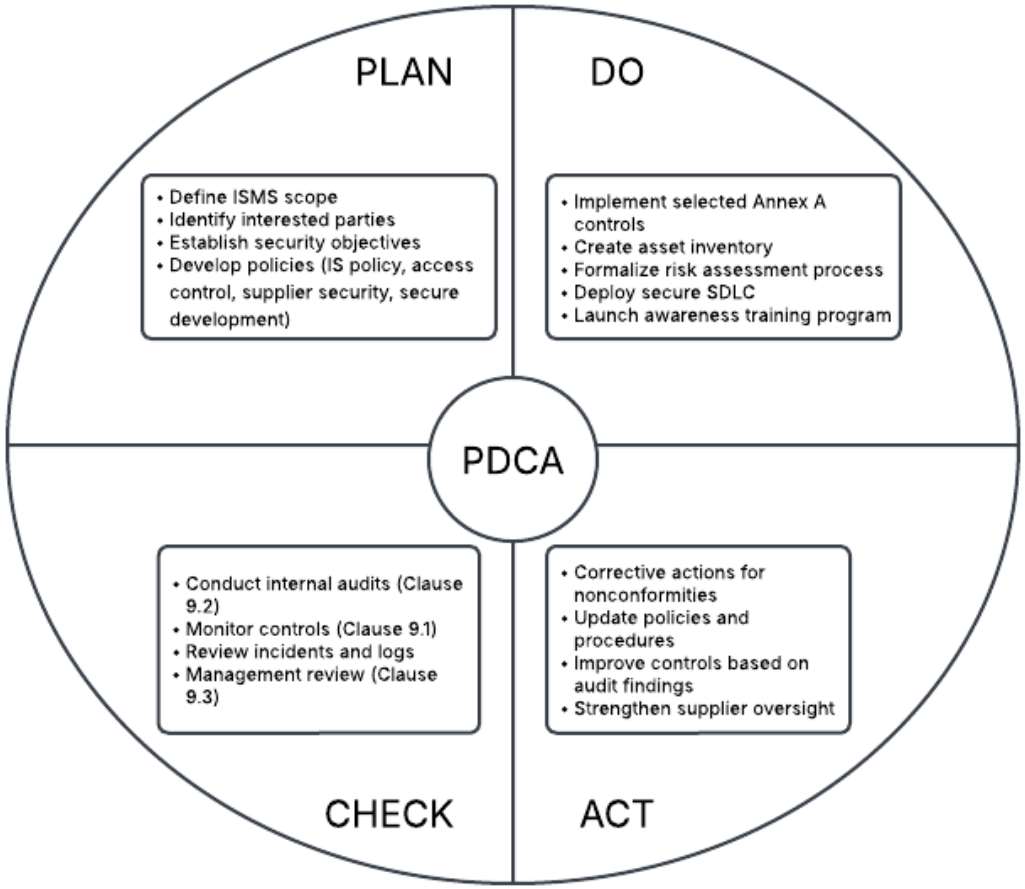


Figure 1: PDCA Improvement Plan

Conclusion

PayNest should treat ISO/IEC 27001 implementation as a business-management programme, not merely as a set of technical controls. By adopting ISO/IEC 27001 requirements and implementing the recommended controls, the company will shift from informal security practices to a structured, risk-based, and continually improving ISMS, positioning it for certification and long-term resilience. PayNest should immediately assign an executive sponsor, appoint a named ISMS owner, and establish an ISMS steering committee. Its first practical deliverables should be the approved scope statement, asset register, risk methodology, risk register, policy framework, and Statement of Applicability. These elements will create the governance structure required to prioritize and evidence the implementation of the high-risk controls recommended in this report.

References

1. International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection—Information security management systems—Requirements* (3rd ed.). ISO.ISO_IEC_27001_2022-en-2-1.pdf
2. International Organization for Standardization & International Electrotechnical Commission. (2022). *ISO/IEC 27001:2022 gap analysis / ISO 27001 implementation material* [Course presentation]. *IEC 27001 (July '26)_Phoenix*.
3. American Council of Training and Development. (n.d.). *PayNest capstone project: Implementing ISO/IEC 27001 for a growing startup.*